

RFC-0001

Arquitetura Base — Plataforma Multi-Tenant de Gestão de Presença

Status: Aprovado e Atualizado (v1.2)

Autor: Equipe de Arquitetura

Data: 07/05/2026

Escopo: Fundação arquitetural e decisões estruturais do MVP

1. Contexto

Este RFC define a fundação arquitetural da plataforma de gestão de presença multi-tenant com validação geográfica e biométrica de grau governamental.

O sistema baseia-se no princípio de *Zero Trust* (Confiança Zero) e na rigorosa separação de domínios de falha. A delegação da autenticação para o Keycloak opera em conjunto com o backend (Spring Boot), estabelecendo que o IAM atua exclusivamente na autenticação da credencial, enquanto o backend assume o papel de resolução da identidade canônica (a pessoa física real) e aplicação de regras de negócio.

Foco desta fase: Arquitetura estrutural correta, evolutiva, resiliente a falhas do IdP e estritamente aderente à LGPD.

2. Objetivos

1. Definir arquitetura técnica do MVP.
 2. Garantir base multi-tenant segura com isolamento de schemas.
 3. Estabelecer separação irrefutável entre a identidade técnica (IAM) e a identidade canônica (Domínio local).
 4. Preparar infraestrutura antifraude com Validação 2x2 para mitigação de sequestro de CPF (*Cross-IdP Impersonation*).
 5. Implementar onboarding obrigatório *durante* o fluxo de login via Custom SPIs.
 6. Operar exclusivamente com tecnologias open source e integrações de fé pública.
-

3. Requisitos Funcionais do MVP

O MVP deve permitir:

- Autenticação OIDC/OAuth2 via Keycloak.

- Criação de entidade organizacional.
 - Preenchimento de perfil obrigatório integrado ao fluxo de login.
 - Associação de usuários via código de convite ou bootstrap via LDAP.
 - Registro de presença (evento bruto imutável).
 - Captura efêmera de biometria facial para prova de vida e geolocalização.
-

4. Requisitos Não Funcionais

- Multi-tenancy com isolamento lógico via schemas funcionais (pessoa, segurança e folha_ponto).
 - Resiliência estrutural a *reset* de banco de dados do IAM (Zero Data Loss).
 - Retenção temporária da mídia fonte biométrica em storage isolado (S3) com expurgo automatizado via agendamento (Cron).
 - Auditoria rastreável (Envers / Triggers).
 - Execução via contêineres Docker.
 - Arquitetura evolutiva (monolito modular).
-

5. Modelo Conceitual de Domínio

As entidades físicas que suportam o domínio foram estruturadas com base na flexibilização de chaves primárias: **UUIDs** para o domínio isolado multi-tenant e **Inteiros Sequenciais (int8)** para domínios globais.

5.1 Identidade Canônica Global (Schema pessoa)

A arquitetura estabelece três camadas rigorosas de abstração de identidade para suportar falhas do Keycloak e múltiplos logins da mesma pessoa:

- **pessoa.pessoa (PK: int8)**: Tabela raiz que concentra a entidade biológica ou estrutural.
- **pessoa.pessoa_fisica (PK: int8)**: Ramificação ancorada no **CPF** (chave canônica inegociável e imutável).
- **seguranca.identidade_acesso (PK: int8)**: Tabela associativa 1:N vital que vincula a **pessoa** aos múltiplos identificadores técnicos efêmeros (**keycloak_sub**) e **provedor**. É esta tabela que garante o princípio de **Zero Data Loss**, permitindo a recuperação integral do histórico da pessoa caso o banco do Keycloak seja corrompido ou resetado.

5.2 IAM e Controle de Acesso (Schema segurança) - Resiliência a Desastres

Atua como a ponte entre o Provedor de Identidade externo e as lógicas internas. Garante o princípio de **Zero Data Loss**:

- **seguranca.identidade_acesso (PK: int8)**: Tabela associativa 1:N vital que vincula o CPF da **pessoa** aos múltiplos identificadores técnicos efêmeros (**keycloak_sub**) e **provedor**.
- **seguranca.perfil_biometrico (PK: uuid)**: Mantém o Hash Biométrico vetorial do usuário.

- **seguranca.dispositivo (PK: uuid):** Cadastro de hardwares (devices) confiáveis.
- **seguranca.log_auditoria (PK: uuid):** Trilha centralizada de eventos e rejeições críticas de segurança.

5.3 Gestão Multi-Tenant e Negócio (Schema `folha_ponto`)

- `folha_ponto.organizacao (PK: uuid):` Representa o locatário (tenant) ou órgão público.
- `folha_ponto.unidade (PK: uuid):` Delimita os locais físicos (geofence) da organização.
- `folha_ponto.vinculo_usuario (PK: uuid):` Relaciona a conta técnica autenticada ao papel (Role) dentro de uma organização específica.
- `folha_ponto.registro_presenca (PK: uuid):` Concentra os eventos brutos, coordenadas de GPS e links para os templates biométricos.

6. Bounded Contexts Propostos

A arquitetura estabelece a divisão estrita de responsabilidades:

1. **Identidade Técnica (Keycloak):** Valida a posse da credencial técnica e emite um token efêmero.
2. **Controle e Identidade de Segurança (Schema `seguranca`):** Resolve a pessoa real através do cruzamento do **sub** com o CPF na tabela **identidade_acesso** e orquestra biometrias e permissões avançadas.
3. **Pessoa Canônica (Schema `pessoa`):** A abstração final da biologia, endereços e parentescos.
4. **Organization Management & Attendance (Schema `folha_ponto`):** Gestão do tenant, controle de acesso dinâmico de negócio e captura de eventos de presença.
5. **Attendance Capture & Biometric Validation:** Processamento do evento bruto de presença.

7. Estratégia de Multi-Tenancy (Schema Funcional)

- **Banco de dados único.**
- **Múltiplos Schemas Funcionais:** Separação tríplice entre pessoa, segurança e o domínio multi-tenant `folha_ponto`
- Isolamento lógico em tabelas de negócio através do pilar `organizacao_id`.

8. Estratégia de IAM (Keycloak) e Lightweight Tokens

8.1 Integração com AD/LDAP (Bootstrap Stateless)

- O parâmetro `Import Users` ficará em `Off`. O LDAP atua como autenticador em tempo real (cortando acesso imediato caso o servidor saia do órgão).
- O AD servirá para o preenchimento automático (*Bootstrap*) das tabelas de `unidade` e `vinculo_usuario`. Modificações subsequentes na estrutura de setores ocorrem no banco PostgreSQL.

8.2 Claims OIDC e Lightweight Tokens

A arquitetura proíbe expressamente o transporte de PII (CPF, Endereços) e Biometria dentro do Access Token. O token deve ser utilitário (*Lightweight Token*), contendo apenas:

- `sub` (Identificador técnico imutável).
 - `email` e `preferred_username`.
 - **profile_complete (Flag Booleana Customizada)**: Claim injetada via Mapper no Keycloak para agilizar o roteamento no SPA React, sinalizando se o usuário já ultrapassou o fluxo de completude obrigatório.
-

9. Biometria e Antifraude (Validação 2x2 e Descarte de Mídia)

9.1 Mitigação de Sequestro de Identidade (Validação 2x2)

Para impedir o *Cross-IdP Impersonation* (um invasor usar um login social novo e amarrar ao CPF de terceiros), a criação do vínculo inicial na tabela `identidade_acesso` exige um **Protocolo de Validação 2x2**. A face em tempo real e o CPF informados no Frontend devem ser orquestrados pelo Spring Boot contra uma entidade de fé pública (ex: Serpro/Datavali) simultaneamente (Biográfica + Biométrica). Somente após aprovação governamental o `sub` do Keycloak é atrelado ao CPF no banco de dados. O motor Python interno será utilizado para a validação cotidiana da folha de ponto.

9.2 Ciclo de Vida e Expurgo da Mídia Fonte (Compliance LGPD)

Diferente de sistemas não regulados, a retenção de mídias fotográficas rasterizadas (.JPG/.PNG) brutas da face gera um imenso passivo perante a LGPD. A "selfie" capturada na autenticação ou no ponto diário será transmitida para uma área de armazenamento de ativos (*Object Storage* isolado via SeaweedFS/S3) atuando como uma Quarentena Visual para Sindicâncias e Auditorias de Curto Prazo. O sistema extrairá o Hash Biométrico (template matemático/vetorial) armazenando-o permanentemente no banco de dados estruturado. A imagem original no S3 possuirá um ciclo de vida estrito e temporário, sendo objeto de expurgo automatizado (hard delete) pelo Spring Boot (via CRON job agendado) tão logo o prazo político de auditoria retenção expire, garantindo a conformidade regulatória.

10. Fluxo Orquestrado de Login (Custom SPI e Action Tokens)

A completude de perfil (Foto, CPF, GPS) **não pode ser relegada a uma tela após a emissão do token final**. Ela deve ser imposta dentro do *pipeline* de autenticação:

1. **Acesso:** O usuário tenta acessar a aplicação React e é redirecionado ao Keycloak.
 2. **Autenticação:** O usuário fornece a credencial (LDAP/Google) e o Keycloak valida matematicamente a senha.
 3. **Interceptação (Custom Authenticator SPI):** Um plugin customizado no Keycloak pausa o login e faz uma requisição (M2M) ao Backend Spring Boot, consultando se aquele sub possui o CPF e atributos básicos preenchidos.
 4. **Onboarding Obrigatório:** Se o backend responder que está incompleto, o SPI emite um **Action Token** (JWT de curtíssima duração) e redireciona o usuário para uma rota pública do React.
 5. **Captura no SPA:** O React captura via WebRTC a foto, o GPS e o CPF do usuário, submetendo tudo ao Spring Boot com o Action Token anexado.
 6. **Validação e Persistência:** O Spring Boot executa a Validação 2x2 (Serpro), extrai o Hash Biométrico (descartando a imagem original da memória) e persiste a Identidade Canônica.
 7. **Retomada da Sessão:** O React redireciona o usuário de volta ao endpoint do Action Token no Keycloak. Um *ActionTokenHandler SPI* valida a conclusão da tarefa, retoma a sessão exata onde havia parado e gera o Access Token definitivo contendo a claim `profile_complete = true`.
-

11. Auditoria e Rastreabilidade

- Todas as recusas biométricas, vínculos criados na tabela **identidade_acesso** e passagens de registro devem ser registradas com **IP Address** e carimbo de tempo na tabela **seguranca.log_auditoria**.
 - Tabelas de histórico temporal utilizam mecanismo de snapshots de revisão (Envers).
 - **Regra de Ouro:** O evento bruto da tabela `registro_presenca` é gerado sob Comando Único e jamais é apagado ou sobrescrito estruturalmente.
-

12. Conclusão Estratégica

Este RFC estabelece um modelo de engenharia de segurança que transcende um simples registro de ponto, alcançando grau governamental. Ao implementar a Identidade Canônica Centralizada, o uso de Lightweight Tokens, o fluxo orquestrado via SPIs e a Validação Dupla de Fé Pública, a plataforma é blindada contra vazamentos, fraudes de representação facial e perdas catastróficas de dados provenientes do provedor de identidade técnico.
